

Manual 24 — NIS2 Controlled Implementation

Controlled English master — development

****Series order:**** 24

****Primary EU baseline:**** Directive (EU) 2022/2555 (NIS2)

****Source-layer rule:**** Directive obligations, Member State transposition law, Commission implementing acts, ENISA or competent-authority guidance, sector-specific requirements, contractual requirements, and internal procedures remain distinct.

****Boundary:**** This manual is an implementation aid, not legal advice, regulator approval, certification, or a substitute for applicable national law or competent-authority instructions.

01. Applicability and entity classification

Determine whether each legal entity and service falls within NIS2 using the Directive, Annex I/II sector criteria, size-cap rules and exceptions, Member State identification decisions, and the applicable national transposition measure. Distinguish essential entities, important entities, and entities outside scope; do not infer classification from sector name alone.

****Control record:**** source layer and jurisdiction; entity/service facts; classification rationale; accountable legal/compliance owner; evidence location; review method; exception or remediation path; and reassessment trigger for organizational, service, size, ownership, sector, or legal change.

02. Jurisdiction, establishment, and cross-border scope

Identify the Member State or Member States with jurisdiction, relevant establishments, any required EU representative, service locations, and cross-border dependencies. Resolve conflicts or uncertainty through the applicable national framework and competent-authority channels rather than assuming one EU-wide filing route.

****Control record:**** jurisdictional source; establishments and service map; accountable legal owner; determination procedure; supporting evidence; periodic validation; unresolved-jurisdiction escalation; and reassessment on restructuring or market-entry change.

03. Essential and important entity governance

Maintain a documented governance model appropriate to the entity classification. Management bodies must approve cybersecurity risk-management measures where the applicable NIS2 implementation requires it and oversee their implementation; governance records should demonstrate decisions, challenge, ownership, escalation, and remediation tracking.

****Control record:**** applicable Article 20/national source layer; management-body applicability; accountable executive and board/governing body; approval and oversight procedure; minutes or decision evidence; governance-effectiveness review; remediation owner; and reassessment after material control or leadership change.

04. Management-body competence and training

Provide management-body members with training sufficient to identify cybersecurity risks and assess cybersecurity risk-management practices and their impact on services. Maintain workforce training appropriate to roles, exposure, and national implementation requirements.

****Control record:**** source layer; population in scope; training owner; curriculum and completion procedure; attendance and competency evidence; effectiveness review; overdue-training remediation; and reassessment after role, threat, or regulatory change.

05. Cybersecurity risk-management framework

Maintain an all-hazards, proportionate cybersecurity risk-management framework covering network and information systems used for operations or service delivery. Define risk criteria, appetite or tolerance, assessment cadence, treatment options, exceptions, control ownership, dependencies, and residual-risk acceptance.

****Control record:**** Directive Article 21/national source; scoped systems and services; risk owner; assessment and treatment procedure; risk register and acceptance evidence; effectiveness review; overdue-treatment escalation; and reassessment after significant change or incident.

06. Policies on risk analysis and information-system security

Maintain approved policies for cybersecurity risk analysis and information-system security. Policies should translate legal and risk requirements into enforceable responsibilities, minimum controls, exceptions, evidence expectations, and review cycles.

****Control record:**** applicable source; policy scope; accountable policy owner; approval/change procedure; controlled policy artifact; compliance review; exception/remediation process; and scheduled or event-driven reassessment.

07. Asset, service, data, and dependency scope

Maintain current inventories of legal entities, business services, network and information systems, information assets, data, interfaces, privileged paths, critical suppliers, facilities, and upstream/downstream dependencies. Map material technical assets to services and accountable owners.

****Control record:**** source layer; inventory applicability; asset/service owner; discovery and reconciliation procedure; inventory and dependency-map evidence; completeness testing; missing-asset remediation; and reassessment after acquisition, deployment, retirement, or architecture change.

08. Incident handling

Maintain incident-handling capabilities covering detection, triage, severity assessment, command, containment, eradication, recovery, evidence preservation, communication, legal/regulatory routing, and lessons learned. Keep internal severity models distinct from legal significance determinations.

****Control record:**** applicable legal and internal sources; incident population; incident commander and regulatory owner; response procedure; ticket/timeline/evidence record;

exercises and post-incident review; corrective-action path; and reassessment after material incidents or exercises.

09. Business continuity, backup, disaster recovery, and crisis management

Implement continuity controls appropriate to service and cyber risk, including backup management, disaster recovery, crisis management, alternate processing, restoration priorities, recovery dependencies, communication, and return-to-service validation.

****Control record:**** Article 21/national source; critical services and systems; continuity owner; BCP/DR execution procedure; backup and exercise evidence; recovery-objective testing; gap remediation; and reassessment after service or dependency change.

10. Supply-chain security

Address cybersecurity risks arising from direct suppliers and service providers, including vulnerabilities specific to each supplier and the overall quality and cybersecurity practices of providers. Evaluate concentration, dependency, subcontracting, location, access, data handling, resilience, and exit feasibility proportionate to risk.

****Control record:**** applicable source layer; supplier/service scope; third-party risk owner; due-diligence and monitoring procedure; assessment/contract/evidence repository; periodic and event-driven review; remediation or exit path; and reassessment on material supplier change or incident.

11. Secure acquisition, development, and maintenance

Apply security controls across acquisition, architecture, development, integration, testing, deployment, configuration, change, patching, maintenance, and retirement of network and information systems. Incorporate security requirements and acceptance criteria before production use.

****Control record:**** source layer; systems and projects in scope; engineering/product owner; secure-lifecycle procedure; design/test/change evidence; control-effectiveness testing; defect/exception remediation; and reassessment after significant architecture, software, or threat change.

12. Vulnerability handling and disclosure

Maintain vulnerability discovery, intake, validation, prioritization, remediation, disclosure, and coordination processes. Track exploitable exposure, compensating controls, affected services, supplier dependencies, deadlines, risk acceptance, and closure evidence.

****Control record:**** Article 21/national and applicable disclosure sources; asset applicability; vulnerability owner; handling/disclosure procedure; scanner/ticket/advisory evidence; remediation verification; exception escalation; and reassessment on new exploitability or threat intelligence.

13. Effectiveness assessment of cybersecurity measures

Establish policies and procedures to assess whether cybersecurity risk-management measures are effective. Use control testing, technical validation, metrics, audits, exercises,

independent review where appropriate, and evidence-based remediation rather than policy existence alone.

****Control record:**** applicable source; control population; assurance owner; testing methodology; test results and supporting evidence; issue validation; remediation/retest path; and reassessment based on risk, failure, or material change.

14. Basic cyber hygiene and cybersecurity training

Define and enforce baseline cyber hygiene practices, including secure configuration, patching, malware protection, phishing resistance, credential hygiene, workstation/server protections, safe administration, and role-based cybersecurity training.

****Control record:**** source layer; workforce/system applicability; security operations and training owners; operating procedure; configuration/training evidence; sampling or technical testing; remediation path; and reassessment after threat, technology, or workforce change.

15. Cryptography and encryption

Maintain policies and procedures governing cryptography and, where appropriate, encryption. Define approved algorithms and protocols, key generation/storage/rotation/revocation, certificate management, secrets handling, data-at-rest/in-transit requirements, exceptions, and migration from deprecated mechanisms.

****Control record:**** applicable source and risk basis; systems/data in scope; cryptographic control owner; key and certificate procedures; configuration/key-management evidence; technical review; exception/remediation path; and reassessment after cryptographic or platform change.

16. Human resources security, access control, and asset management

Apply personnel-security controls appropriate to role and risk, least-privilege access, joiner/mover/leaver processes, privileged-access governance, periodic access review, segregation of duties, asset assignment, return, and ownership controls.

****Control record:**** source layer; workforce/accounts/assets in scope; IAM/HR/asset owners; lifecycle procedure; access and asset evidence; recertification and sampling; exception/remediation path; and reassessment after role, employment, privilege, or asset change.

17. Multi-factor authentication and secure communications

Use multi-factor authentication or continuous-authentication solutions, secured voice/video/text communications, and secured emergency communication systems where appropriate under the applicable NIS2 implementation and risk assessment. Document where a measure is not applicable or feasible when the governing source permits such qualification.

****Control record:**** source layer; users/systems/communications applicability; IAM or communications owner; implementation procedure; configuration and coverage evidence;

technical testing; exception/remediation path; and reassessment after architecture or risk change.

18. Logging, monitoring, and detection

Maintain risk-based logging and monitoring sufficient to detect anomalous activity, unauthorized access, integrity failures, service disruption, security-control failure, and material supplier events. Protect log integrity, synchronize time, define retention, and preserve evidence needed for investigation and reporting.

****Control record:**** applicable source; systems/services in scope; SOC/operations owner; monitoring procedure; log-source/use-case evidence; coverage and detection testing; gap remediation; and reassessment after system, threat, or incident change.

19. Significant-incident determination

Maintain a legally controlled process to determine whether an incident is significant under Directive Article 23, the applicable national transposition measure, and any directly applicable implementing act. Do not use internal severity alone as the legal trigger. For entities within Commission Implementing Regulation (EU) 2024/2690, apply its significance criteria only within that Regulation's stated entity scope.

****Control record:**** exact legal source and entity scope; incident facts; regulatory decision owner; determination worksheet; evidence and rationale; legal/compliance review; correction/escalation path; and reassessment as incident facts evolve.

20. Early warning and incident notification

For essential and important entities subject to the Directive reporting sequence, maintain capability to submit an early warning without undue delay and in any event within 24 hours of awareness of a significant incident, followed by an incident notification without undue delay and in any event within 72 hours, subject to applicable national routing and any legally applicable special rule. Preserve the distinct 24-hour trust-service-provider rule where applicable and reverify all filing instructions at operational use.

****Control record:**** current source/timing rule; entity and incident applicability; reporting owner; clock-start and submission procedure; timestamped filing evidence; deadline/quality review; late or defective filing remediation; and reassessment on new facts or authority instructions.

21. Intermediate, progress, and final incident reports

Maintain capability to provide an intermediate report when requested and a final report no later than one month after the incident notification, subject to the Directive's ongoing-incident progress-report rule and applicable national implementation. The final report should capture severity/impact, likely threat or root cause, mitigation, and cross-border impact where applicable.

****Control record:**** exact reporting source; incident applicability; regulatory reporting owner; report-preparation procedure; submitted report and receipt evidence; completeness review; correction/remediation path; and reassessment until incident handling and regulatory closure are complete.

22. Communications to affected service recipients

Where applicable, communicate without undue delay to service recipients potentially affected by a significant cyber threat the measures or remedies they can take, and where appropriate inform them of the threat itself. Coordinate regulatory, legal, security, customer, privacy, and communications functions so that notices are accurate and do not compromise response activity.

****Control record:**** legal source and recipient applicability; communications owner; approval and delivery procedure; notice/recipient/delivery evidence; timeliness and completeness review; correction path; and reassessment as threat or impact changes.

23. Entity registration and authority-facing data

Maintain the data required for applicable Member State entity lists and, for entity types covered by Directive Article 27, the information supporting the ENISA registry process through national single points of contact. Track names, sector/type, establishments or representative details, current contact information, service jurisdictions, IP ranges where required, and change-notification obligations under the governing source.

****Control record:**** exact national/EU source; registration applicability; legal/compliance owner; submission/change procedure; filed data and receipt evidence; periodic accuracy review; correction path; and reassessment after corporate, contact, network, or service change.

24. Domain-name registration data controls

Where Directive Article 28 and national implementing law apply, maintain accurate and complete domain-name registration data with due diligence and applicable data-protection controls. Keep collection, verification, disclosure, access, and retention procedures aligned with the precise legal role of the TLD registry or domain-name registration service provider.

****Control record:**** source and role applicability; data owner; collection/verification/disclosure procedure; database and request evidence; accuracy/privacy review; remediation path; and reassessment after legal, system, or registration-data change.

25. Sector and implementing-regulation overlays

Maintain a controlled overlay for sector-specific and entity-type-specific requirements. Commission Implementing Regulation (EU) 2024/2690 must be applied to its defined relevant entities—such as specified DNS/TLD, cloud, data-centre, CDN, managed-service, managed-security, online-marketplace/search/social-platform, and trust-service providers—and not generalized to unrelated NIS2 entities.

****Control record:**** overlay source and entity type; applicability decision; sector/regulatory owner; mapping procedure; requirement-to-control evidence; periodic source review; gap remediation; and reassessment after service, classification, or legislative change.

26. Commission Implementing Regulation 2024/2690 control mapping

For entities within Regulation (EU) 2024/2690, map the Annex's technical and methodological requirements to operating controls and evidence. Where that Regulation

permits a requirement to be applied only where appropriate, applicable, or feasible, document any non-application reasoning comprehensibly and retain the supporting risk basis.

****Control record:**** exact Regulation provision; relevant-entity applicability; accountable control owner; mapping and implementation procedure; control/evidence matrix; conformity and effectiveness review; remediation or documented non-application path; and reassessment after risk or service change.

27. Supplier evidence and chain assurance

Maintain evidence demonstrating that supplier-security requirements operate in practice, not only in contract language. Collect and evaluate service descriptions, data/access locations, security attestations, testing evidence, incident history, vulnerabilities, continuity capabilities, subcontractors, material changes, concentration, and exit readiness according to risk.

****Control record:**** source and supplier scope; third-party owner; evidence-collection procedure; supplier dossier; review/testing method; issue escalation/remediation; and reassessment on renewal, material change, incident, or new intelligence.

28. Exercises, testing, and remediation validation

Exercise incident response, continuity, crisis management, communications, supplier disruption, recovery, and decision-making under plausible scenarios. Validate remediation through retesting or other evidence appropriate to the finding; do not close material issues on assertion alone.

****Control record:**** source/risk basis; tested scope; assurance or resilience owner; exercise/test procedure; plan/results/evidence; finding validation; remediation and retest path; and reassessment based on test outcome or changing risk.

29. Metrics, thresholds, and management reporting

Define decision-useful metrics for risk, incidents, reporting readiness, vulnerabilities, patching, access, training, supplier exposure, continuity, testing, exceptions, and remediation. Keep operational thresholds distinct from legal incident-significance criteria and document escalation logic.

****Control record:**** source and risk basis; metric population; metric owner; calculation/reporting procedure; source data and reports; data-quality/effectiveness review; correction path; and reassessment when risks, systems, or legal thresholds change.

30. Exceptions, corrective actions, and supervisory readiness

Operate a controlled exception and remediation lifecycle with risk basis, accountable owner, approver, compensating controls, due date, evidence, reassessment trigger, and closure verification. Preserve records needed to support competent-authority supervision and enforcement interactions according to entity classification and applicable national law.

****Control record:**** governing source; issue/exception applicability; accountable risk and remediation owners; workflow; approval and closure evidence; independent or management review; escalation/retest path; and reassessment until verified closure.

31. Localization and legal-source control

Translate only from an exact frozen English source. Preserve legal terms, entity classifications, source-layer distinctions, incident-significance logic, reporting stages and timing, implementing-regulation scope, national-law caveats, and unofficial-translation status. Legal-source references may be localized for readability but must remain traceable to the same controlling provision.

****Control record:**** frozen-source identity; locale applicability; localization owner/reviewer; controlled translation procedure; parity evidence; semantic and structural review; correction/retranslation path; and reassessment after any English or source change.

32. Source watch, provenance, accessibility, and release

Before candidate freeze and publication, reverify the current Directive (EU) 2022/2555 text, applicable national transposition measures for the intended use case, Commission implementing acts including Regulation (EU) 2024/2690 where relevant, current ENISA and competent-authority materials, incident-reporting instructions, and sector overlays. Bind the exact English source commit, localized sources, DOCX/PDF binaries, SHA-256 identities, rendered and accessibility QA, workflow-security results, substantive-review evidence where required, predecessor publication state, and catalog/release-registry reconciliation. If any material source, applicability, localization, integrity, packaging, accessibility, provenance, security, or substantive defect remains unresolved, publication fails closed.

****Control record:**** release-time source set; publication applicability; release owner; candidate/reconciliation procedure; provenance manifest and QA evidence; exact-head review; remediation/regeneration path; and reassessment after any material source or artifact change.

Controlled implementation minimum

Each chapter must be implemented through evidence appropriate to the organization's facts and jurisdiction. At minimum, records must identify the controlling source layer, applicability decision, accountable owner, operating procedure, evidence object and location, review or test method, exception/remediation path, and reassessment trigger. National transposition law and competent-authority instructions control where they impose jurisdiction-specific requirements that differ from this generic implementation architecture.